

PROJET DE LABORATOIRE IT / CYBERSECURITE

Infrastructure Simulee d'Entreprise avec Securisation Avancee

Document technique — Portfolio professionnel

Niveau : Licence / Junior IT | Outils : VMware, Linux, Windows Server, pfSense

SOMMAIRE

1. Resume de l'architecture et description des machines virtuelles
2. Schema logique de l'architecture et flux reseau
3. Description du projet
4. Architecture technique
5. Etapes de realisation detaillees
6. Implementation reseau
7. Implementation systeme (Linux + Windows Server)
8. Securite : hardening, journalisation, controle d'accès
9. Mini audit de securite
10. Livrables finaux
11. Competences demontrees

1. RESUME DE L'ARCHITECTURE — CE QU'IL FAUT SAVOIR AVANT DE COMMENCER

Le laboratoire simule le SI d'une PME fictive appelee NEXACORP. L'infrastructure tourne entierement sur une seule machine hote (Lenovo ThinkPad i5, 12 Go RAM, 256 Go SSD) via VMware Workstation. Cinq machines virtuelles sont deployees. Voici le role precis de chacune, les ressources allouees et les points cles a connaitre avant de commencer.

VM	OS	RAM	Disque	Role principal	Adresse IP
VM1 pfSense-FW	pfSense 2.7 (FreeBSD)	512 Mo	8 Go	Pare-feu/routeur NAT, VLAN, firewall rules, DNS relay	LAN: 192.168.10.1 DMZ: 192.168.20.1 WAN: NAT/DHCP hote
VM2 WinSrv-AD	Windows Server 2022 Eval (180j)	2 Go	40 Go	Controleur de domaine Active Directory DNS interne GPO, DHCP	192.168.10.10 Domaine: nexacorp.local
VM3 Linux-Web	Ubuntu Server 22.04 LTS	1 Go	20 Go	Serveur web (Apache) Serveur applicatif DMZ exposee Hardening Linux	192.168.20.10
VM4 Linux-Log	Ubuntu Server 22.04 LTS	1 Go	20 Go	Serveur de logs centralises (Rsyslog + Fail2ban) SIEM leger	192.168.10.20
VM5 Win10-Client	Windows 10 (21H2 ISO gratuit)	1.5 Go	30 Go	Poste client domaine Tests AD/GPO Navigation web	DHCP -> LAN

Details importants par machine

VM1 — pfSense-FW (Pare-feu/Routeur)

C'est la piece centrale du reseau. Elle separe trois segments : LAN (postes internes et AD), DMZ (serveur web expose), WAN (acces internet via NAT depuis la machine hote). Toute la segmentation reseau passe par elle. pfSense est une distribution open source basee FreeBSD, administrable via interface web (HTTPS sur port 443 depuis le LAN). La version 2.7 est stable et telechargeable gratuitement sur netgate.com. En termes de ressources, 512 Mo RAM suffisent largement pour ce labo.

Points d'attention : lors de l'installation dans VMware, il faut creer 3 interfaces reseau (NAT pour WAN, Host-Only pour LAN, Host-Only separe pour DMZ). L'interface de gestion est accessible depuis VM5 (client) via le navigateur.

VM2 — WinSrv-AD (Controleur de domaine Active Directory)

Windows Server 2022 Evaluation est telechargeable gratuitement sur le site de Microsoft (licence 180 jours, largement suffisant pour un labo). Cette VM fait office de controleur de domaine pour nexacorp.local, serveur DNS interne, et serveur DHCP pour le LAN. Elle gere les comptes utilisateurs, groupes de securite et GPO (Group Policy Objects) qui s'appliquent sur VM5. Elle ne doit jamais etre exposee en DMZ. 2 Go RAM est le minimum strict pour AD DS sous Server 2022.

Points d'attention : installer les roles AD DS, DNS et DHCP dans cet ordre. Promouvoir le serveur en DC cree automatiquement la zone DNS nexacorp.local. Desactiver IPv6 si non utilise pour eviter les conflits de resolution DNS.

VM3 — Linux-Web (Serveur web en DMZ)

Ubuntu Server 22.04 LTS (ISO telechargeable gratuitement sur ubuntu.com). Heberge un site web fictif de NEXACORP via Apache2. C'est la seule machine accessible depuis le WAN (port 80/443 ouvert via regles pfSense). C'est aussi la machine sur laquelle on simule des failles (ex: mauvaises permissions, services inutiles actifs) pour la partie audit. Le hardening Linux est applique dessus en priorite.

Points d'attention : installer sans interface graphique (mode server). SSH n'est accessible que depuis le LAN (pas depuis WAN). Les logs Apache sont envoyes vers VM4 via Rsyslog.

VM4 — Linux-Log (Serveur de logs centralises)

Ubuntu Server 22.04 LTS. Recoit les logs de toutes les autres machines via Rsyslog (UDP/TCP 514). Fait tourner Fail2ban pour detecter les tentatives de bruteforce SSH. Peut heberger un dashboard leger via Logwatch ou GoAccess pour visualiser les evenements. C'est le composant SIEM minimal du labo. Il n'a pas acces a internet (pas de route WAN) pour etre isole.

Points d'attention : bien ouvrir le port 514 dans le pare-feu local (ufw) et sur pfSense (LAN interne). Creer une partition /var/log separee si possible.

VM5 — Win10-Client (Poste client du domaine)

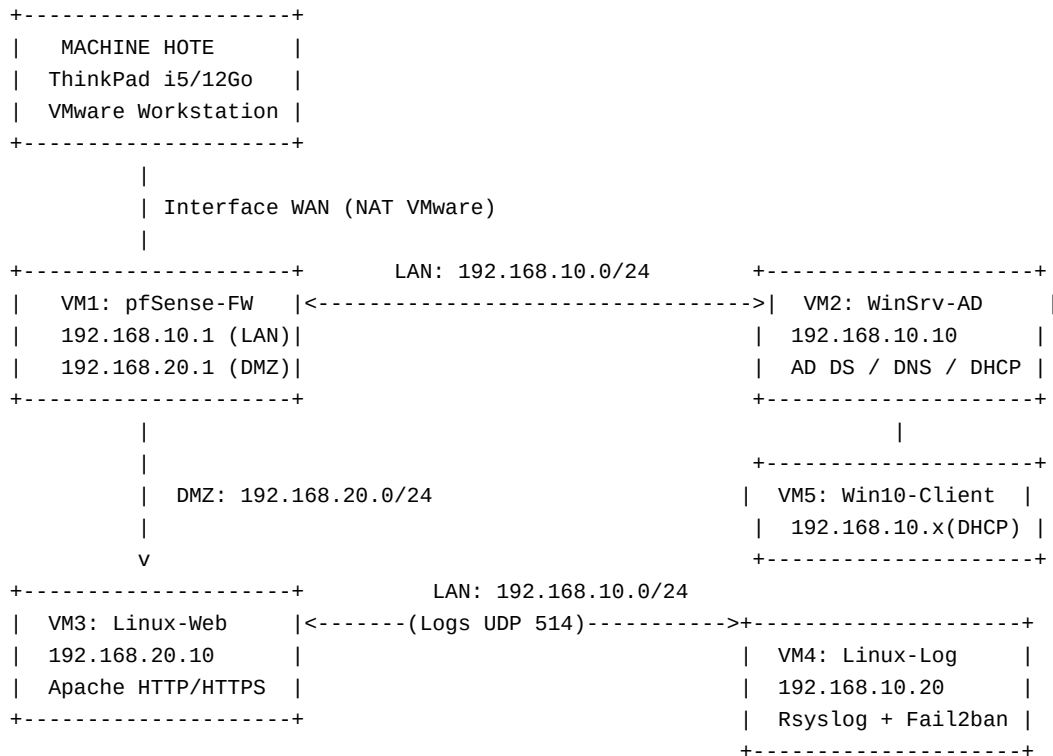
Windows 10 (ISO Media Creation Tool, gratuit). Joint au domaine nexacorp.local. Recoit les GPO depuis VM2. Sert a tester la connexion utilisateur, l'application des politiques de securite, la navigation vers le site web de VM3, et l'administration de pfSense depuis le navigateur. C'est depuis cette machine qu'on realise les tests fonctionnels.

Points d'attention : joindre le domaine uniquement apres que VM2 est operationnel et que DNS pointe vers 192.168.10.10. Allouer 1.5 Go minimum, 2 Go si possible.

Total RAM utilisee : environ 6 Go sur 12 Go disponibles. Les 6 Go restants sont pour l'OS hote (Windows + VMware). Ne pas faire tourner toutes les VM simultanement si la RAM est insuffisante : demarrer d'abord VM1 (pfSense) et VM2 (AD), puis les autres selon le besoin.

2. SCHEMA LOGIQUE DE L'ARCHITECTURE ET FLUX RESEAU

Le schema ci-dessous est une representation textuelle de l'infrastructure. L'etudiant doit reproduire ce schema sous forme de diagramme (draw.io recommande, gratuit et en ligne) comme livrable.



FLUX RESEAU AUTORISES:

WAN -> DMZ : TCP 80, 443 (vers VM3 uniquement)
LAN -> WAN : TCP/UDP any (NAT pfSense)
LAN -> DMZ : TCP 80, 443, 22 (SSH admin vers VM3)
DMZ -> LAN : REFUSE (sauf logs UDP 514 vers VM4)
DMZ -> WAN : REFUSE
LAN -> pfSense : TCP 443 (interface admin, depuis VM5 uniquement)
VM2 <-> VM5 : Kerberos 88, LDAP 389, SMB 445, DNS 53
Toutes VMs -> VM4 : UDP/TCP 514 (Rsyslog)

3. DESCRIPTION DU PROJET

3.1 Nom du projet

NEXACORP-LAB — Infrastructure SI simulee avec segmentation reseau, administration systeme et securisation avancee.

3.2 Contexte

NEXACORP est une PME fictive de 20 employes, active dans la distribution de logiciels B2B. Elle dispose d'un site web public, d'un annuaire interne pour gerer les acces employes, et d'un reseau local segmente. Le responsable IT (l'etudiant) doit deployer et securiser l'infrastructure depuis zero : reseau, serveurs, postes clients, pare-feu, journalisation et audit.

3.3 Objectif global

Deployer une infrastructure IT complete et fonctionnelle simulant un environnement professionnel reel, en appliquant les bonnes pratiques de securite a chaque couche (reseau, systeme, application, identite).

3.4 Resultat final attendu

- Reseau segmente en 3 zones (LAN / DMZ / WAN) avec regles de filtrage operationnelles
- Domaine Active Directory fonctionnel avec GPO de securite appliquees
- Serveur web Apache en DMZ, accessible depuis le WAN, inaccessible en interne sauf SSH
- Journalisation centralisee de tous les evenements sur VM4
- Audit de securite documente avec failles identifiees et corrections appliquees
- Documentation technique complete et screenshots de validation

4. ARCHITECTURE TECHNIQUE

4.1 Reseaux VMware a creer

Dans VMware Workstation, creer les reseaux virtuels suivants via Virtual Network Editor :

Nom VMware	Type	Subnet	Usage
VMnet8 (NAT)	NAT	DHCP auto	WAN pfSense — acces internet
VMnet2	Host-Only	192.168.10.0/24	LAN — AD, clients, logs
VMnet3	Host-Only	192.168.20.0/24	DMZ — serveur web

4.2 Configuration reseau de chaque VM dans VMware

VM1 pfSense : Adaptateur 1 = VMnet8 (NAT/WAN), Adaptateur 2 = VMnet2 (LAN), Adaptateur 3 = VMnet3 (DMZ)

VM2 WinSrv-AD : Adaptateur 1 = VMnet2 (LAN), IP statique 192.168.10.10/24, Gateway 192.168.10.1, DNS 127.0.0.1

VM3 Linux-Web : Adaptateur 1 = VMnet3 (DMZ), IP statique 192.168.20.10/24, Gateway 192.168.20.1, DNS 192.168.10.10

VM4 Linux-Log : Adaptateur 1 = VMnet2 (LAN), IP statique 192.168.10.20/24, Gateway 192.168.10.1, DNS 192.168.10.10

VM5 Win10-Client : Adaptateur 1 = VMnet2 (LAN), DHCP depuis VM2

5. ETAPES DE REALISATION DETAILLEES

ETAPE 1 — Installation et configuration de pfSense (VM1)

Objectif

Avoir un pare-feu operationnel avec 3 interfaces, NAT fonctionnel vers internet, et acces a l'interface d'administration depuis le LAN.

Actions

- Telecharger pfSense CE 2.7 ISO depuis netgate.com (environ 600 Mo)
- Creer la VM dans VMware : 512 Mo RAM, 8 Go disque, 3 cartes reseau
- Demarrer l'installation : choisir ZFS ou UFS, installer sur le disque virtuel
- Au premier demarrage, assigner les interfaces : WAN=em0 (VMnet8), LAN=em1 (VMnet2), OPT1=em2 (VMnet3)
- Via le menu console (option 2), configurer LAN IP : 192.168.10.1/24, pas de DHCP sur pfSense LAN (le DHCP sera sur VM2)
- Configurer OPT1 (renommer en DMZ) : 192.168.20.1/24
- Depuis VM5 (une fois deploye), ouvrir <https://192.168.10.1> et terminer la configuration via l'assistant Web

Configuration pfSense via interface web

- System > General : hostname=nexacorp-fw, domain=nexacorp.local, DNS=8.8.8.8 (WAN)
- Interfaces > LAN : verifier IP statique 192.168.10.1/24
- Interfaces > DMZ (OPT1) : activer, IP 192.168.20.1/24
- Firewall > NAT > Outbound : mode hybride, regle pour LAN vers WAN

Outils

pfSense CE 2.7, VMware Workstation, navigateur web depuis VM5

Resultat attendu

VM1 pinguable depuis LAN (192.168.10.1), acces internet depuis VM2/VM4/VM5 via NAT.

ETAPE 2 — Installation et configuration de Windows Server 2022 (VM2)

Objectif

Avoir un controleur de domaine Active Directory operationnel pour nexacorp.local, avec DNS et DHCP fonctionnels sur le LAN.

Telechargement

Windows Server 2022 Evaluation (180 jours) :
<https://www.microsoft.com/en-us/evalcenter/evaluate-windows-server-2022> (ISO ~5 Go, inscription email requise, gratuite)

Actions — Installation

- Creer la VM : 2 Go RAM, 40 Go disque, 1 carte reseau VMnet2
- Installer Windows Server 2022 Standard (Desktop Experience pour GUI)
- Apres installation : configurer IP statique 192.168.10.10/24, Gateway 192.168.10.1, DNS 127.0.0.1
- Renommer le serveur en NEXASRV01

Actions — Roles AD DS, DNS, DHCP

- Server Manager > Add Roles and Features
- Cocher : Active Directory Domain Services + DNS Server + DHCP Server

- Apres installation, cliquer sur 'Promote this server to a domain controller'
- Choisir 'Add a new forest', root domain : nexacorp.local
- DSRM password : a noter soigneusement
- Laisser les options DNS par default, terminer et redemarrer

Actions — DHCP

- Ouvrir DHCP Manager
- Creer un scope LAN : 192.168.10.100 - 192.168.10.200, mask /24
- Options scope : 003 Gateway=192.168.10.1, 006 DNS=192.168.10.10, 015 Domain=nexacorp.local
- Autoriser le serveur DHCP dans AD

Verification

Depuis VM5 apres jonction domaine : nslookup nexacorp.local doit retourner 192.168.10.10

ETAPE 3 — Creation des utilisateurs et groupes AD

Objectif

Simuler une structure organisationnelle avec des comptes a privileges differencies.

Structure OU a creer dans Active Directory Users and Computers

```
nexacorp.local
  ■■■ NEXACORP
    ■■■ OU=Utilisateurs
      ■ ■■■ alice.dupont (groupe: IT-Admins, Domain Users)
      ■ ■■■ bob.martin (groupe: Commerciaux, Domain Users)
      ■ ■■■ claire.ndong (groupe: Direction, Domain Users)
      ■ ■■■ svc-web (compte service, pas de login interactif)
    ■■■ OU=Groupes
      ■ ■■■ IT-Admins (membres: alice.dupont)
      ■ ■■■ Commerciaux (membres: bob.martin)
      ■ ■■■ Direction (membres: claire.ndong)
    ■■■ OU=Ordinateurs
      ■■■ WIN10-CLIENT01
```

Commandes PowerShell equivalentes

```
# Creer les OUs
New-ADOrganizationalUnit -Name "Utilisateurs" -Path "DC=nexacorp,DC=local"
New-ADOrganizationalUnit -Name "Groupes" -Path "DC=nexacorp,DC=local"
New-ADOrganizationalUnit -Name "Ordinateurs" -Path "DC=nexacorp,DC=local"

# Creer les groupes
New-ADGroup -Name "IT-Admins" -GroupScope Global -Path "OU=Groupes,DC=nexacorp,DC=local"
New-ADGroup -Name "Commerciaux" -GroupScope Global -Path "OU=Groupes,DC=nexacorp,DC=local"

# Creer les utilisateurs
New-ADUser -Name "Alice Dupont" -SamAccountName alice.dupont `
  -UserPrincipalName alice.dupont@nexacorp.local `
  -Path "OU=Utilisateurs,DC=nexacorp,DC=local" `
  -AccountPassword (ConvertTo-SecureString "P@ssw0rd123!" -AsPlainText -Force) `
  -Enabled $true

# Ajouter alice au groupe IT-Admins
Add-ADGroupMember -Identity "IT-Admins" -Members alice.dupont
```


ETAPE 4 — GPO de securite

Objectif

Appliquer des politiques de securite centralisees sur les postes clients du domaine.

GPO a creer et lier a OU=Ordinateurs

GPO1 : Politique de mots de passe

```
Computer Configuration > Windows Settings > Security Settings > Account Policies
> Password Policy :
- Minimum password length : 10
- Complexity requirements : Enabled
- Maximum password age : 90 days
> Account Lockout Policy :
- Lockout threshold : 5 attempts
- Lockout duration : 15 minutes
```

GPO2 : Restriction logicielle et acces

```
User Configuration > Administrative Templates > Control Panel :
- Prohibit access to Control Panel : Enabled (pour groupe Commerciaux)
```

```
Computer Configuration > Windows Settings > Security Settings > Local Policies
> User Rights Assignment :
- Allow log on locally : Domain Admins, IT-Admins uniquement
- Deny log on through Remote Desktop : Commerciaux, Direction
```

GPO3 : Journalisation avancee

```
Computer Configuration > Windows Settings > Security Settings
> Advanced Audit Policy Configuration > System Audit Policies :
- Account Logon : Success, Failure
- Logon/Logoff : Success, Failure
- Object Access : Failure
- Privilege Use : Failure
- Account Management : Success, Failure
```

ETAPE 5 — Installation Ubuntu Server — VM3 et VM4

Objectif

Deployer deux instances Ubuntu Server 22.04 LTS avec configuration reseau statique.

Telechargement

ISO Ubuntu Server 22.04 LTS : <https://ubuntu.com/download/server> (~1.4 Go)

Installation (identique pour VM3 et VM4)

- Creer VM : 1 Go RAM, 20 Go disque, 1 carte reseau (VMnet3 pour VM3, VMnet2 pour VM4)
- Choisir 'Ubuntu Server' (sans GUI)
- Lors de la configuration reseau, selectionner configuration manuelle

Configuration reseau statique (Netplan) — VM3

```
# /etc/netplan/00-installer-config.yaml
network:
  version: 2
  ethernets:
    ens33:
      addresses: [192.168.20.10/24]
      gateway4: 192.168.20.1
```

```
nameservers:
  addresses: [192.168.10.10]
dhcp4: no
sudo netplan apply
```

Configuration reseau statique — VM4

```
# /etc/netplan/00-installer-config.yaml
network:
  version: 2
  ethernets:
    ens33:
      addresses: [192.168.10.20/24]
      gateway4: 192.168.10.1
      nameservers:
        addresses: [192.168.10.10]
      dhcp4: no
```

ETAPE 6 — Configuration SSH securise sur VM3 et VM4

Objectif

Acceder aux serveurs Linux de maniere securisee en desactivant les vecteurs d'attaque SSH classiques.

Actions

```
sudo apt update && sudo apt install -y openssh-server
```

```
# Editer /etc/ssh/sshd_config
sudo nano /etc/ssh/sshd_config
```

Parametres a modifier ou verifier dans sshd_config :

```
Port 2222                # Changer le port par default
PermitRootLogin no       # Desactiver login root direct
PasswordAuthentication no # Forcer authentication par cle
PubkeyAuthentication yes
AuthorizedKeysFile .ssh/authorized_keys
MaxAuthTries 3
LoginGraceTime 30
AllowUsers adminweb      # Restreindre aux comptes autorises
X11Forwarding no
Banner /etc/ssh/banner.txt # Ajouter une banniere legale
sudo systemctl restart sshd
```

Generation et deploiement des cles SSH

```
# Sur la machine d'administration (VM5 ou machine hote)
ssh-keygen -t ed25519 -C "admin@nexacorp.local" -f ~/.ssh/nexacorp_key

# Copier la cle publique vers VM3
ssh-copy-id -i ~/.ssh/nexacorp_key.pub -p 2222 adminweb@192.168.20.10

# Copier vers VM4
ssh-copy-id -i ~/.ssh/nexacorp_key.pub -p 2222 adminlog@192.168.10.20
```

ETAPE 7 — Installation et configuration Apache sur VM3

Objectif

Deployer un site web d'entreprise fictif accessible depuis le WAN via pfSense.

Actions

```
sudo apt update && sudo apt install -y apache2 ufw
```

```
# Activer Apache
```

```
sudo systemctl enable apache2
```

```
sudo systemctl start apache2
```

```
# Page web fictive
```

```
sudo nano /var/www/html/index.html
```

Contenu minimal pour index.html :

```
<!DOCTYPE html>
<html>
<head><title>NEXACORP - Solutions Logicielles B2B</title></head>
<body>
<h1>Bienvenue chez NEXACORP</h1>
<p>Site en maintenance. Contactez admin@nexacorp.local</p>
</body>
</html>
```

Configuration du pare-feu local ufw sur VM3

```
sudo ufw default deny incoming
```

```
sudo ufw default allow outgoing
```

```
sudo ufw allow from 192.168.10.0/24 to any port 2222 # SSH depuis LAN uniquement
```

```
sudo ufw allow 80/tcp
```

```
sudo ufw allow 443/tcp
```

```
sudo ufw enable
```

```
sudo ufw status verbose
```

Regles pfSense pour exposer le port 80/443 vers VM3

Sur pfSense, Firewall > NAT > Port Forward :

- Interface : WAN, Protocol : TCP, Dest Port : 80, Redirect IP : 192.168.20.10, Redirect Port : 80

- Interface : WAN, Protocol : TCP, Dest Port : 443, Redirect IP : 192.168.20.10, Redirect Port : 443

Firewall > Rules > DMZ : ajouter regles autorisant TCP 80 et 443 depuis WAN vers 192.168.20.10

ETAPE 8 — Centralisation des logs avec Rsyslog (VM4)

Objectif

Recevoir et stocker les logs de VM2 (Windows), VM3 (Apache/system) en un point central.

Configuration Rsyslog serveur sur VM4

```
sudo apt install -y rsyslog
```

```
# Editer /etc/rsyslog.conf
```

```
sudo nano /etc/rsyslog.conf
```

```
# Décommenter les lignes suivantes pour écouter UDP et TCP 514 :
```

```
module(load="imudp")
```

```
input(type="imudp" port="514")
```

```
module(load="imtcp")
```

```
input(type="imtcp" port="514")
```

```
# Template de stockage par hôte
```

```
$template RemoteLogs, "/var/log/remote/%HOSTNAME%/%PROGRAMNAME%.log"
```

```
*.* ?RemoteLogs
```

```
& ~
```

```
sudo systemctl restart rsyslog
sudo mkdir -p /var/log/remote

# Ouvrir port 514 dans ufw
sudo ufw allow from 192.168.10.0/24 to any port 514
sudo ufw allow from 192.168.20.0/24 to any port 514
```

Configuration Rsyslog client sur VM3

```
# Ajouter a la fin de /etc/rsyslog.conf sur VM3
*. * @192.168.10.20:514      # UDP
*. * @@192.168.10.20:514    # TCP (plus fiable)

# Logs Apache spécifiques
$ModLoad imfile
$InputFileName /var/log/apache2/access.log
$InputFileTag apache-access:
$InputFileStateFile stat-apache-access
$InputFileSeverity info
$InputRunFileMonitor

sudo systemctl restart rsyslog
```

Configuration Windows Event Forwarding — VM2

Sur VM2 (Windows Server), installer NXLog Community Edition (gratuit) pour envoyer les evenements Windows vers Rsyslog sur VM4 :

```
# Après installation NXLog, editor C:\Program Files (x86)\nxlog\conf\nxlog.conf :
<Input in>
  Module im_msvistalog
  Query <QueryList><Query Id="0"><Select Path="Security">*</Select></Query></QueryList>
</Input>
<Output out>
  Module om_udp
  Host 192.168.10.20
  Port 514
  Exec to_syslog_bsd();
</Output>
<Route 1>
  Path in => out
</Route>
```

ETAPE 9 — Installation et configuration de Fail2ban sur VM4

Objectif

Detecter et bloquer automatiquement les tentatives de bruteforce SSH.

```
sudo apt install -y fail2ban

# Creer /etc/fail2ban/jail.local
sudo nano /etc/fail2ban/jail.local

[DEFAULT]
bantime = 3600
findtime = 600
maxretry = 3
backend = systemd

[sshd]
enabled = true
```

```
port      = 2222
logpath   = /var/log/auth.log
maxretry  = 3
```

```
[apache-auth]
enabled   = true
port      = 80,443
logpath   = /var/log/remote/NEXAWEB/apache-access.log
maxretry  = 5
sudo systemctl enable fail2ban
sudo systemctl start fail2ban
sudo fail2ban-client status
sudo fail2ban-client status sshd
```

6. SECURITE — HARDENING COMPLET

6.1 Hardening Linux — VM3 et VM4

Mises a jour automatiques de securite

```
sudo apt install -y unattended-upgrades
sudo dpkg-reconfigure --priority=low unattended-upgrades
# Verifier /etc/apt/apt.conf.d/50unattended-upgrades
```

Desactivation des services inutiles

```
# Lister les services actifs
sudo systemctl list-units --type=service --state=running

# Desactiver les services non necessaires (exemples)
sudo systemctl disable --now avahi-daemon
sudo systemctl disable --now cups
sudo systemctl disable --now bluetooth

# Verifier les ports en ecoute
sudo ss -tulnp
```

Gestion des utilisateurs et privileges

```
# Creer un compte admin dedie (ne pas utiliser ubuntu par default)
sudo adduser adminweb
sudo usermod -aG sudo adminweb

# Verifier les UID 0 (root)
awk -F: '($3 == 0) {print}' /etc/passwd

# Verrouiller les comptes systeme inutilisables
sudo usermod -L sync
sudo usermod -L games
sudo usermod -L news

# Configurer sudo avec log
echo 'Defaults logfile="/var/log/sudo.log"' | sudo tee /etc/sudoers.d/logging
echo 'Defaults log_input,log_output' | sudo tee -a /etc/sudoers.d/logging
```

Parametres kernel de securite (sysctl)

```
# Ajouter a /etc/sysctl.d/99-hardening.conf :
net.ipv4.ip_forward = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.tcp_syncookies = 1
net.ipv4.icmp_echo_ignore_broadcasts = 1
net.ipv4.conf.all.log_martians = 1
kernel.randomize_va_space = 2
fs.suid_dumpable = 0

sudo sysctl -p /etc/sysctl.d/99-hardening.conf
```

Verification de l'integrite des fichiers — Aide

```
sudo apt install -y aide
sudo aideinit
sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
# Verification periodique
```

```
sudo aide --check
```

Banniere SSH legale

```
# /etc/ssh/banner.txt
AVERTISSEMENT : Acces reserve au personnel autorise NEXACORP.
Toute tentative d'accès non autorise est enregistree et peut faire
l'objet de poursuites judiciaires. Deconnectez-vous maintenant si
vous n'etes pas un utilisateur autorise.
```

6.2 Hardening Windows Server 2022 — VM2

Politique de mots de passe via GPO

Deja configure en etape 4 (GPO1). Verifier via : gpresult /R depuis VM5 pour confirmer l'application.

Desactivation de services inutiles

```
# PowerShell – lister services en cours
Get-Service | Where-Object {$_.Status -eq "Running"} | Select-Object Name, DisplayName

# Desactiver les services a risque si non utilises
Set-Service -Name "RemoteRegistry" -StartupType Disabled
Stop-Service -Name "RemoteRegistry"
Set-Service -Name "Telnet" -StartupType Disabled # si present
Set-Service -Name "Fax" -StartupType Disabled
```

Pare-feu Windows — regles restrictives

```
# PowerShell – n'autoriser que les ports AD necessaires
New-NetFirewallRule -DisplayName "Block RDP externe" `
  -Direction Inbound -Protocol TCP -LocalPort 3389 `
  -RemoteAddress "192.168.10.0/24" -Action Allow
New-NetFirewallRule -DisplayName "Block tout reste" `
  -Direction Inbound -Action Block -Enabled True
```

Audit et journalisation Windows

```
# Activer l'audit via GPO (deja vu etape 4)
# Verifier dans Event Viewer > Windows Logs > Security
# Filtrer Event ID importants :
# 4624 : connexion reussie
# 4625 : echec de connexion
# 4720 : creation de compte
# 4726 : suppression de compte
# 4728/4732 : ajout a un groupe
# 7045 : service installe (potentiel malware)

# Augmenter la taille des journaux
wevtutil sl Security /ms:204800000 # 200 Mo pour le journal Security
```

Principe du moindre privilege — verification

```
# Verifier les membres du groupe Administrateurs
Get-ADGroupMember -Identity "Domain Admins" -Recursive

# Ne doivent apparaitre que :
# - Administrator (compte builtin)
# - alice.dupont (IT-Admins)

# Verifier les comptes avec droit de connexion locale
Get-GPResultantSetOfPolicy -ReportType Html -Path C:\GPReport.html
```

6.3 Regles pfSense — Politique de filtrage complete

Regles LAN

Permettre : LAN -> WAN : TCP/UDP any (NAT)
Permettre : LAN -> DMZ : TCP 80, 443, 2222
Permettre : LAN -> LAN : TCP 53, 88, 389, 445, 636 (AD services)
Permettre : LAN -> pfSense : TCP 443 (admin, source=192.168.10.10 et VM5 uniquement)
Refuser : tout le reste

Regles DMZ

Permettre : DMZ -> LAN (VM4 uniquement) : UDP 514 (logs)
Permettre : DMZ -> LAN (VM2 uniquement) : TCP 53 (DNS)
Refuser : DMZ -> tout WAN
Refuser : DMZ -> LAN (autres destinations)

Regles WAN

Permettre : WAN -> DMZ (VM3) : TCP 80, 443
Refuser : tout le reste (implicite pfSense)

7. MINI AUDIT DE SECURITE

L'objectif est d'introduire volontairement des failles, de les detecter avec des outils open source, de les documenter et de les corriger. Cela simule un pentest interne basique.

7.1 Failles a introduire volontairement

Faillle 1 — SSH root autorise sur VM3

```
# Modifier temporairement /etc/ssh/sshd_config sur VM3
PermitRootLogin yes
PasswordAuthentication yes
# Puis : sudo systemctl restart sshd
```

Faillle 2 — Service Telnet installe et actif sur VM3

```
sudo apt install -y telnetd
sudo systemctl enable inetd
sudo systemctl start inetd
```

Faillle 3 — Fichier sensible accessible en lecture monde

```
echo "motdepasse_db=sup3rS3cr3t" | sudo tee /etc/nexacorp.conf
sudo chmod 644 /etc/nexacorp.conf # lisible par tous les utilisateurs
```

Faillle 4 — Compte AD sans expiration de mot de passe

```
# Sur VM2, via PowerShell
Set-ADUser -Identity bob.martin -PasswordNeverExpires $true
```

Faillle 5 — Regle pfSense trop permissive en DMZ

```
# Ajouter temporairement : DMZ -> WAN : any any (permet exfiltration de donnees)
```

7.2 Detection des failles

Outil 1 : Nmap (scan de ports depuis VM4 vers VM3)

```
sudo apt install -y nmap

# Scan complet de VM3 depuis VM4
sudo nmap -sV -sC -O -p- 192.168.20.10 -oN /tmp/scan_vm3.txt

# Resultat attendu (avec failles) :
# PORT      STATE SERVICE VERSION
# 22/tcp    open  ssh      OpenSSH 8.9 (PermitRootLogin=yes detecte par banner)
# 23/tcp    open  telnet   Linux telnetd
# 80/tcp    open  http     Apache httpd 2.4.52
```

Outil 2 : Lynis (audit de securite systeme sur VM3)

```
sudo apt install -y lynis
sudo lynis audit system 2>&1 | tee /tmp/lynis_report.txt

# Points d'attention dans le rapport :
# [WARNING] PermitRootLogin is set to YES
# [WARNING] Telnet is enabled
# [SUGGESTION] File permissions on /etc/nexacorp.conf
```

Outil 3 : Detection faille AD — PowerShell sur VM2

```
# Lister les comptes avec mot de passe qui n'expire jamais
Search-ADAccount -PasswordNeverExpires -UsersOnly |
```

```
Select-Object Name, SamAccountName, PasswordNeverExpires
```

```
# Lister les comptes inactifs depuis 30 jours
Search-ADAccount -AccountInactive -TimeSpan 30.00:00:00 -UsersOnly |
Select-Object Name, LastLogonDate
```

Outil 4 : Verification des permissions sur fichiers sensibles

```
# Depuis VM3
find /etc -maxdepth 1 -type f -perm /o+r 2>/dev/null
stat /etc/nexacorp.conf
# Output doit montrer : Other : r-- (lisible par tous = FAILLE)
```

7.3 Corrections a appliquer

Correction faille 1 — SSH

```
# /etc/ssh/sshd_config
PermitRootLogin no
PasswordAuthentication no
sudo systemctl restart sshd
```

Correction faille 2 — Telnet

```
sudo systemctl stop inetd
sudo systemctl disable inetd
sudo apt remove -y telnetd
sudo apt autoremove -y
```

Correction faille 3 — Permissions fichier

```
sudo chmod 600 /etc/nexacorp.conf
sudo chown root:root /etc/nexacorp.conf
```

Correction faille 4 — AD

```
Set-ADUser -Identity bob.martin -PasswordNeverExpires $false
Set-ADUser -Identity bob.martin -ChangePasswordAtLogon $true
```

Correction faille 5 — pfSense

Supprimer la règle DMZ -> WAN : any. Remettre uniquement UDP 514 vers VM4.

Validation post-correction

```
# Relancer Nmap apres corrections
sudo nmap -sV -p 22,23,80 192.168.20.10
# Port 23 doit etre ferme
# Re-lancer Lynis pour verifier la disparition des warnings
```

8. LIVRABLES FINAUX

L'etudiant doit produire les elements suivants pour constituer son portfolio :

8.1 Documentation technique (fichier PDF ou Markdown)

- Architecture reseau : description des VMs, plans d'adressage, segments
- Procédures d'installation pas a pas avec commandes utilisees
- Politique de securite appliquee : regles firewall, GPO, hardening
- Rapport d'audit : failles introduites, methodes de detection, corrections
- Incidents detectes via Fail2ban et logs (extraits des journaux)

8.2 Diagramme d'architecture

- Reproduire le schema logique section 2 dans draw.io (app.diagrams.net, gratuit)
- Exporter en PNG et PDF
- Inclure : IP de chaque machine, segments reseau, flux autorises et refuses, legende

8.3 Screenshots obligatoires

Les captures suivantes constituent les preuves de realisation :

1. pfSense - Interface dashboard avec les 3 interfaces up (WAN/LAN/DMZ)
2. pfSense - Tableau des regles firewall (LAN, DMZ, WAN)
3. pfSense - Journal des connexions (Firewall Logs)
4. AD - Arborescence OU dans Active Directory Users and Computers
5. AD - Proprietes d'un utilisateur (ex: alice.dupont, groupes, GPO)
6. AD - Resultat gpresult /R depuis VM5 montrant les GPO appliquees
7. VM3 - curl `http://192.168.20.10` retournant la page NEXACORP
8. VM3 - ufw status verbose montrant les regles actives
9. VM3 - Sortie Lynis AVANT corrections (avec warnings)
10. VM3 - Sortie Lynis APRES corrections (warnings resolu)
11. VM4 - `/var/log/remote/` avec sous-dossiers par machine
12. VM4 - fail2ban-client status sshd (avec IPs bannies si possible)
13. Nmap - Scan avant/apres montrant fermeture du port 23
14. VM5 - Connexion au domaine nexacorp.local confirmee
15. VM5 - Tentative de connexion avec un compte non autorise (echec attendu, GPO)

8.4 Fichier de configuration export

- Export des regles pfSense : Diagnostics > Backup & Restore > Download config.xml
- Export GPO : GPMC > clic droit sur GPO > Save Report (HTML)
- Export configuration Rsyslog, sshd_config, sysctl.conf

9. COMPETENCES DEMONTREES

Domaine	Competence specifique	Niveau prouve
Reseau	Segmentation LAN/DMZ/WAN, NAT, routage inter-VLAN	Operationnel
Reseau	Configuration et administration d'un pare-feu pfSense	Operationnel
Reseau	Connaissance des protocoles TCP/IP, DNS, DHCP	Solide
Linux	Administration Ubuntu Server, gestion paquets apt	Operationnel
Linux	Configuration SSH, clés ed25519, restriction acces	Avance
Linux	Hardening systeme : sysctl, permissions, services	Avance
Linux	Centralisation logs Rsyslog, analyse journaux	Operationnel
Windows	Deploiement Active Directory Domain Services	Operationnel
Windows	Creation OU, utilisateurs, groupes de securite	Operationnel
Windows	Conception et application de GPO de securite	Operationnel
Securite	Identification et exploitation de failles reelles	Conscient
Securite	Audit systeme avec Lynis, scan reseau avec Nmap	Operationnel
Securite	Detection intrusion avec Fail2ban	Operationnel
Securite	Principe du moindre privilege applique	Avance
Securite	Documentation et rapport d'audit	Demonstrable

Ce que ce projet signifie pour un recruteur

Un candidat ayant realise et documente ce projet montre qu'il est capable de deployer une infrastructure IT complete sans assistance, de comprendre les interactions entre les composants (reseau, identite, services, journalisation), d'appliquer des pratiques de securite reelles et de documenter son travail de maniere professionnelle. Ce niveau correspond au profil d'un technicien systeme/reseau junior ou d'un candidat a un poste en cybersecurite junior/SOC Tier 1.

10. RESSOURCES DE TELECHARGEMENT

Tous les outils utilisés sont gratuits. Voici les URLs officielles :

Ressource	URL de telechargement	Taille approx.
pfSense CE 2.7	https://www.netgate.com/pfsense-plus-software/how-to-buy#pfsense-ce	~600 Mo
Windows Server 2022 Eval	https://www.microsoft.com/en-us/evalcenter/evaluate-windows-server-2022	~5 Go
Ubuntu Server 22.04 LTS	https://ubuntu.com/download/server	~1.4 Go
Windows 10 ISO	https://www.microsoft.com/en-us/software-download/windows10	~5 Go
VMware Workstation Player	https://www.vmware.com/products/workstation-player.html	~600 Mo
NXLog Community Ed.	https://nxlog.co/downloads/nxlog-ce	~30 Mo
draw.io (diagramme)	https://app.diagrams.net (en ligne, sans installation)	N/A

Note sur la connexion internet limitée

Les ISO représentent un total d'environ 12-13 Go. Si la connexion est lente, privilégier le téléchargement en plusieurs sessions ou via un partage local. Une fois les ISO disponibles, l'ensemble du projet peut être réalisé hors ligne. Les installations apt (Ubuntu) requièrent internet uniquement lors du apt update/install ; ces paquets (openssh-server, apache2, rsyslog, fail2ban, nmap, lynis, aide) font chacun moins de 50 Mo et peuvent être téléchargés un par un selon disponibilité.